МІНІСТЕРСТВО ОСВІТИ І НАУКИ УКРАЇНИ

КИЇВСЬКИЙ НАЦІОНАЛЬНИЙ УНІВЕРСИТЕТ ІМЕНІ ТАРАСА ШЕВЧЕНКА

ФАКУЛЬТЕТ ІНФОРМАЦІЙНИХ ТЕХНОЛОГІЙ

КАФЕДРА ІНФОРМАЦІЙНИХ СИСТЕМ ТА ТЕХНОЛОГІЙ

Лабораторна робота № 2

з дисципліни **«Кібернетична безпека підприємства»**

Тема: «Аналіз процесу управління ризиками кібернетичної безпеки військкомату (ТЦК та СП) за методикою CRAMM»

Виконав:

студент гр. ІР-31

Петро Кравченко

Перевірив:

Зараховано від

Борисенко Ірина Ігорівна

_____

(підпис викладача)

Київ-2026

ЗМІСТ

1. МЕТА ТА ЗАВДАННЯ РОБОТИ 3
2. ПОНЯТТЯ УПРАВЛІННЯ РИЗИКАМИ 4
2.1. Ризик, загроза, вразливість 4
2.2. Управління ризиками та способи обробки 4
3. ПРОЦЕС УПРАВЛІННЯ РИЗИКАМИ НА ПІДПРИЄМСТВІ 6
3.1. Етапи процесу 6
3.2. Процесний підхід у методичних рекомендаціях 7
4. МЕТОДОЛОГІЯ CRAMM ТА ЇЇ ЗАСТОСУВАННЯ ДО ТЦК ТА СП 8
4.1. Загальна характеристика CRAMM 8
4.2. Етапи CRAMM 8
4.3. Етап 1: ідентифікація та оцінка активів ТЦК та СП 10
4.4. Етап 2: оцінка загроз, вразливостей і міри ризику 11
4.5. Етап 3: вибір контрзаходів 13
5. АСПЕКТИ УПРАВЛІНСЬКОЇ РОБОТИ ЩОДО ЗАБЕЗПЕЧЕННЯ ІБ У ТЦК ТА СП 15
6. МЕТОДИКИ УПРАВЛІННЯ РИЗИКАМИ ДЛЯ ТЦК ТА СП 18
7. ПЕРЕВАГИ ТА НЕДОЛІКИ МЕТОДИК УПРАВЛІННЯ РИЗИКАМИ ІБ 20
8. ВІДПОВІДІ НА ПИТАННЯ ДЛЯ САМОПЕРЕВІРКИ 21
ВИСНОВКИ 22
СПИСОК ВИКОРИСТАНИХ ДЖЕРЕЛ 23

1. МЕТА ТА ЗАВДАННЯ РОБОТИ

Мета роботи — за допомогою методики CRAMM (CCTA Risk Analysis and Management Method) навчитися процесу управління ризиками інформаційної безпеки підприємства [1]. Об’єкт дослідження, як і в лабораторній роботі 1, — військкомат за індивідуальним варіантом № 24, тобто районний територіальний центр комплектування та соціальної підтримки (далі — ТЦК та СП) [2].

Завдання роботи відповідно до методичних рекомендацій [1]:

1) дослідити поняття управління ризиками (розділ 2);

2) дослідити процес управління ризиками на підприємстві (розділ 3);

3) дослідити методологію CRAMM і застосувати її до ТЦК та СП (розділ 4);

4) перерахувати основні аспекти управлінської роботи щодо забезпечення інформаційної безпеки на рівні підприємства за індивідуальним варіантом (розділ 5);

5) заповнити таблицю методик, які можуть бути застосовані для безпеки підприємства, розширивши перелік методиками, що найкраще підходять для діяльності ТЦК та СП (розділ 6);

6) заповнити таблицю переваг і недоліків методик управління ризиками ІБ (розділ 7).

Відповіді на питання для самоперевірки наведено в розділі 8, аналіз результатів — у висновках. Активи, загрози та вразливості взято з моделі лабораторної роботи 1, що забезпечує наскрізність досліджень.

Примітка. ТЦК та СП, його підрозділи, інформаційна система й усі числові оцінки в роботі є умовною навчальною моделлю, побудованою лише на відкритих нормативних джерелах.

2. ПОНЯТТЯ УПРАВЛІННЯ РИЗИКАМИ

2.1. Ризик, загроза, вразливість

Кіберризик — це ймовірність реалізації кіберзагрози з урахуванням потенційних негативних наслідків для підприємства: загроза характеризує можливе джерело або сценарій небажаної події, а ризик враховує ймовірність її реалізації та величину збитків [3]. Загроза — потенційна небезпека для інформаційної системи, вразливість — її слабке місце, атака — практична реалізація дій, спрямованих на використання цієї слабкості [3]. Отже, ризик існує лише там, де є одночасно цінний ресурс, загроза для нього і вразливість, через яку загроза може реалізуватися.

У стандартах ризик визначають як вплив невизначеності на цілі [4], а ризик інформаційної безпеки пов’язують з можливістю того, що загроза використає вразливість активу й завдасть шкоди організації [5]. У методиці CRAMM ця залежність виражена прямо: міра ризику визначається поєднанням цінності активу, рівня загрози та рівня вразливості [6].

2.2. Управління ризиками та способи обробки

Управління ризиками — скоординована діяльність зі спрямування й контролю організації щодо ризиків [4]. Для інформаційної безпеки це безперервний цикл виявлення, оцінювання, обробки ризиків і контролю результатів, який є основою системи інформаційної безпеки підприємства [1]. Управління інформаційною безпекою на рівні підприємства спрямоване на нейтралізацію зовнішніх загроз (неправомірні дії, злочинна діяльність, збої глобальних систем і систем партнерів) і внутрішніх (помилки й халатність персоналу, навмисні порушення, збої власних систем) і має здійснюватися в контексті загальної діяльності підприємства [1].

Для кожного оціненого ризику обирають один зі способів обробки [4; 5]:

– зменшення (модифікація) — впровадження заходів, що знижують ймовірність або наслідки: для ТЦК та СП — багатофакторна автентифікація операторів Реєстру;

– уникнення — відмова від діяльності, що породжує ризик: наприклад, заборона обробки мобілізаційних документів на мережевих АРМ;

– передавання (розподіл) — перекладання частини наслідків на іншу сторону: захист від DDoS-атак провайдером, вимоги безпеки в договорах з постачальниками;

– прийняття (збереження) — свідоме рішення власника ризику не обробляти ризик, рівень якого не перевищує критеріїв прийнятності.

Механізмами управління ризиками на підприємстві є політика й критерії прийняття ризиків, призначення власників ризиків, методика оцінювання, реєстр ризиків, план обробки, внутрішній аудит і аналіз керівництвом [7]. Для ТЦК та СП власником ризиків є начальник, а методику та реєстр веде служба захисту інформації (розділ 5).

3. ПРОЦЕС УПРАВЛІННЯ РИЗИКАМИ НА ПІДПРИЄМСТВІ

3.1. Етапи процесу

Процес управління ризиками інформаційної безпеки за ISO/IEC 27005 і ISO 31000 подано на рис. 2.1. Він починається зі встановлення контексту й містить оцінювання ризиків (ідентифікацію, аналіз і оцінювання), обробку та прийняття ризиків, а комунікація й моніторинг супроводжують усі етапи [4; 5].

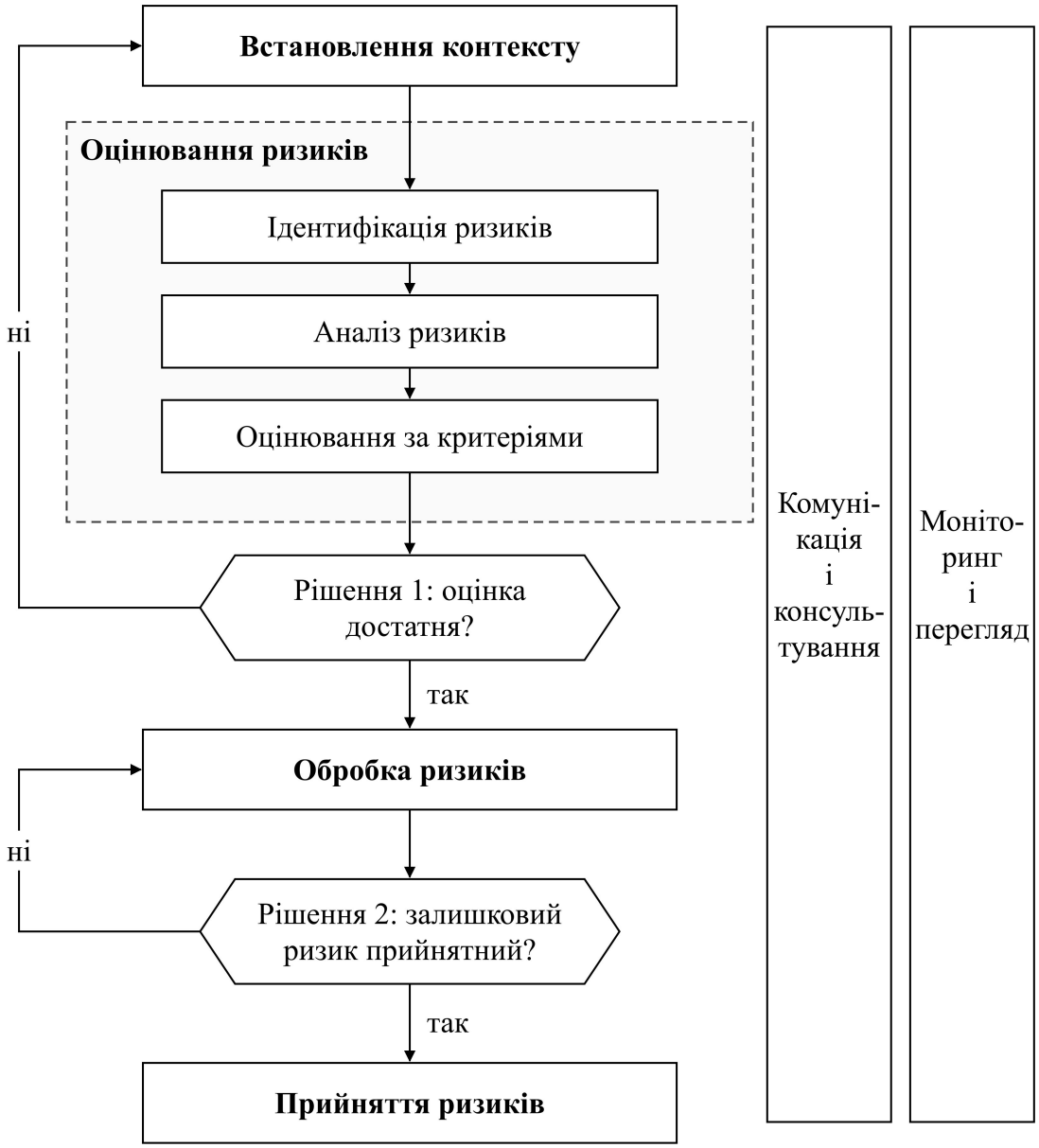


Рис. 2.1 — Процес управління ризиками інформаційної безпеки з точками прийняття рішень

Дві точки рішень роблять процес ітеративним. Якщо після оцінювання інформації недостатньо для рішення (рішення 1), повертаються до встановлення контексту й уточнюють межі або критерії. Якщо залишковий ризик після обробки неприйнятний (рішення 2), обирають додаткові заходи. Наповнення етапів для ТЦК та СП наведено в табл. 2.1.

Таблиця 2.1 — Етапи процесу управління ризиками в ТЦК та СП

Етап	Зміст	Результат для ТЦК та СП
Встановлення контексту	межі, критерії оцінки та прийняття ризиків, зацікавлені сторони	область СУІБ — процеси П1–П7 ЛР1; прийнятна міра ризику CRAMM — не більше 4
Ідентифікація	активи, загрози, вразливості, наявні заходи, наслідки	6 груп даних і 5 груп ПЗ та фізичних активів; 10 загроз З-01…З-10
Аналіз	оцінка цінності активів, рівнів загроз і вразливостей	цінність 1–10, загроза 1–5, вразливість 1–3 (етапи 1–2 CRAMM)
Оцінювання	зіставлення міри ризику з критеріями, пріоритизація	ризики з мірою 5–7 обробляються першочергово
Обробка	вибір способу обробки й заходів, план обробки ризиків	контрзаходи за групами CRAMM (табл. 2.5)
Прийняття	рішення власника щодо залишкових ризиків	наказ начальника ТЦК та СП про прийняття залишкових ризиків
Комунікація, моніторинг	інформування сторін, перегляд ризиків після змін та інцидентів	щоквартальний звіт керівнику СУІБ, переоцінка після інцидентів

3.2. Процесний підхід у методичних рекомендаціях

Методичні рекомендації подають систему інформаційної безпеки як процес управління ризиками з шести складових: опис бізнес-процесів, збір ризиків, оцінка ризиків, планування заходів, реалізація заходів і оцінка ефективності [1]. Ці складові відповідають етапам рис. 2.1: опис процесів — встановленню контексту, збір і оцінка ризиків — оцінюванню, планування та реалізація заходів — обробці, оцінка ефективності — моніторингу й перегляду. Види заходів (організаційні, правові, організаційно-технічні, програмні, інженерно-технічні) використано в розділі 4.4.

4. МЕТОДОЛОГІЯ CRAMM ТА ЇЇ ЗАСТОСУВАННЯ ДО ТЦК ТА СП

4.1. Загальна характеристика CRAMM

Методику CRAMM розробило Центральне агентство з комп'ютерів і телекомунікацій Великобританії (Central Computer and Telecommunications Agency, CCTA) на замовлення британського уряду; її використовують з 1985 року державні й комерційні організації [1]. За даними інвентаризації ENISA, перший випуск методу й однойменного програмного засобу датовано 1985 роком, версію 5 — 2003 роком, постачальником засобу була компанія Insight Consulting, а сама методика є бажаним методом аналізу ризиків для урядових установ Великобританії й особливо придатна для великих організацій [8].

В основу CRAMM покладено комплексний підхід, що поєднує кількісні та якісні методи; бази знань (профілі) засобу відрізняються для комерційних і державних організацій [1]. Метою розроблення методики було отримати формалізовану процедуру, яка дає змогу повністю проаналізувати вимоги безпеки, уникнути зайвих витрат, обґрунтувати контрзаходи, порівнювати їх варіанти та генерувати звіти [1].

4.2. Етапи CRAMM

Методика поділяє процедуру на три послідовні етапи (рис. 2.2). Перший етап відповідає на запитання, чи достатньо засобів базового рівня, чи потрібен детальніший аналіз; на другому ідентифікують ризики та оцінюють їх величину; на третьому обирають адекватні контрзаходи [1].

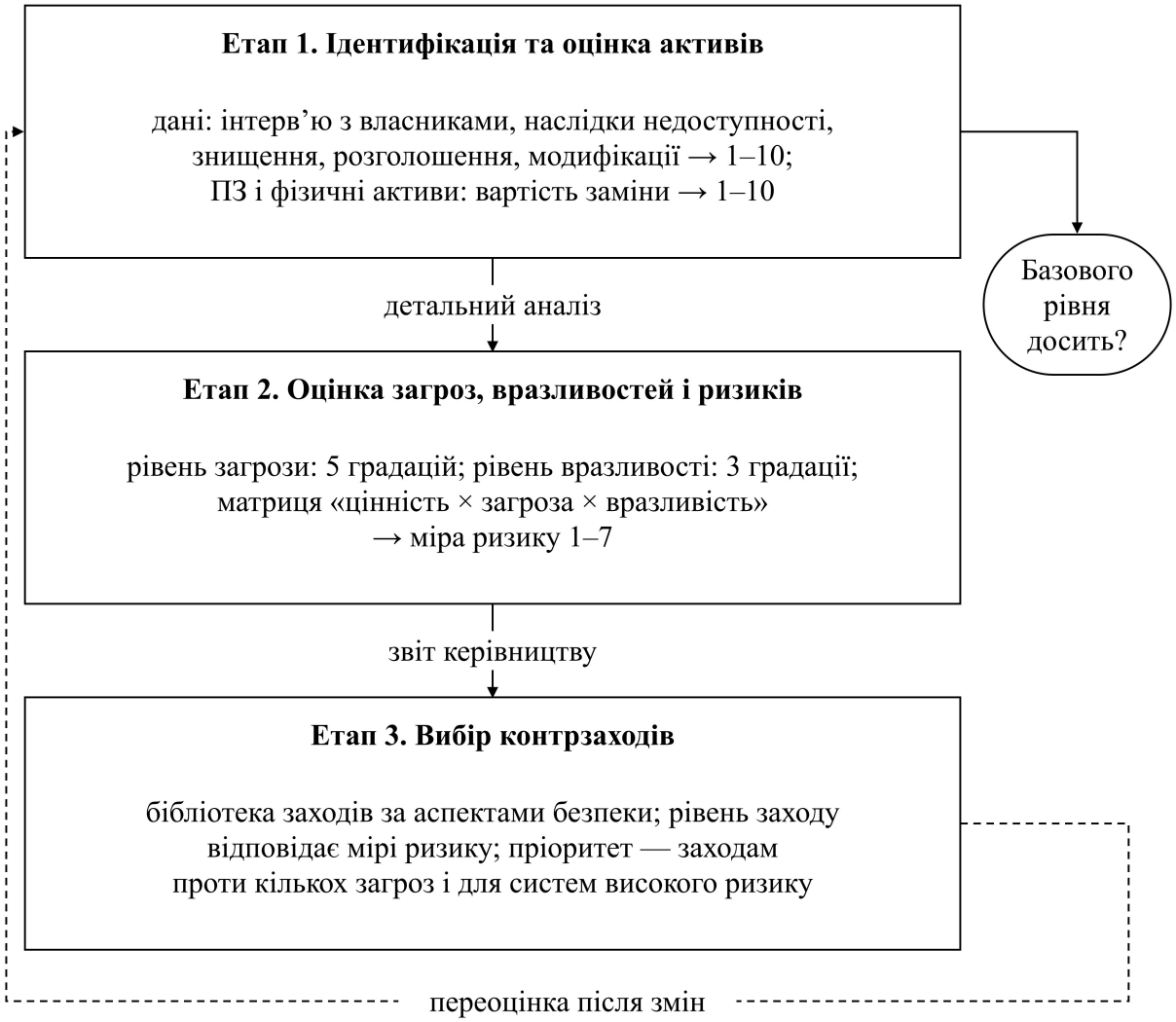


Рис. 2.2 — Етапи методики CRAMM та шкали оцінювання

Шкали CRAMM такі [6]. Цінність даних визначають в інтерв'ю з їх власниками через наслідки найгірших сценаріїв недоступності, знищення, розголошення та модифікації і переводять у шкалу 1–10; прикладне ПЗ і фізичні активи оцінюють за вартістю заміни в тій самій шкалі, а також успадковують цінність даних, які вони обробляють. Рівень загрози має п'ять градацій (дуже низький … дуже високий), рівень вразливості — три (низький, середній, високий). Засіб CRAMM за вбудованою матрицею перетворює поєднання цінності, загрози та вразливості на міру ризику від 1 (базові вимоги безпеки) до 7 (дуже високі вимоги). Бібліотеку з майже 4000 контрзаходів згруповано за аспектами безпеки: апаратні, програмні, комунікаційні, процедурні, фізичні, кадрові та середовищні [6].

4.3. Етап 1: ідентифікація та оцінка активів ТЦК та СП

Оцінки цінності даних (табл. 2.2) отримано за принципом CRAMM — від власників даних, через наслідки найгіршого сценарію для кожного з чотирьох видів порушення. Цінність активу дорівнює найбільшій з чотирьох оцінок.

Таблиця 2.2 — Етап 1 CRAMM: оцінка цінності даних ТЦК та СП (шкала 1–10)

Код	Дані	Респондент (власник)	Недоступність	Знищення	Розголошення	Модифікація	Цінність
Д1	Відомості Реєстру — дані органу ведення (А-01)	начальник відділення військового обліку	8	8	9	10	10
Д2	Медичні висновки та протоколи ВЛК (А-02)	голова ВЛК	6	7	9	8	9
Д3	Мобілізаційні розпорядження та плани (А-03)	начальник ТЦК та СП	9	8	10	9	10
Д4	Біометричні дані та фотозображення (А-04)	начальник відділення військового обліку	3	5	9	7	9
Д5	Справи соціальної підтримки	начальник відділення соціальної підтримки	5	5	6	6	6
Д6	Журнали подій безпеки (А-10)	служба захисту інформації	4	7	5	8	8

Прикладне ПЗ та фізичні активи (табл. 2.3) оцінено за вартістю заміни; якщо вони обробляють цінніші дані, їхня цінність підвищується до цінності цих даних, як це робить засіб CRAMM.

Таблиця 2.3 — Етап 1 CRAMM: оцінка ПЗ та фізичних активів

Код	Актив	Тип	Вартість заміни	Дані	Цінність
П1	Клієнтське ПЗ органу ведення Реєстру на АРМ (А-06)	прикладне ПЗ	4	Д1, Д4	10
П2	Вебсервіс електронної черги (А-08)	прикладне ПЗ	4	—	4
Ф1	Сервер документообігу та АРМ операторів (А-06)	фізичний	5	Д2, Д5, Д6	9
Ф2	Криптошлюз КЗІ та канали обміну (А-05, А-07)	фізичний	7	Д1	10
Ф3	Приміщення РСО з автономними АРМ (А-03)	фізичний	6	Д3	10

Відповідь на запитання першого етапу: 9 активів мають цінність 8 і вище (Д1, Д2, Д3, Д4, Д6, П1, Ф1, Ф2, Ф3), тому засобів базового рівня недостатньо і для ТЦК та СП потрібен детальний аналіз ризиків (етап 2). Базовий рівень захисту прийнятний лише для сервісу електронної черги П2 як відокремленого ресурсу з відкритою інформацією.

4.4. Етап 2: оцінка загроз, вразливостей і міри ризику

Для груп активів оцінено рівні загроз і вразливостей за шкалами CRAMM (табл. 2.4). Оригінальна матриця засобу CRAMM не публікується, тому в роботі міру ризику R обчислено монотонною апроксимацією, що зберігає шкали та напрям впливу кожного чинника:

$$R = 1 + \text{округл}(2{,}5\cdot(V-1)/9 + 2\cdot(T-1)/4 + 1{,}5\cdot(U-1)/2),$$

де V — цінність групи активів (1–10, найбільша в групі), T — рівень загрози (1–5), U — рівень вразливості (1–3). Найменшим значенням чинників відповідає R = 1, найбільшим — R = 7.

Таблиця 2.4 — Етап 2 CRAMM: загрози, вразливості та міра ризику для ТЦК та СП

Активи	Загроза	V	Загроза (T)	Вразли-вість (U)	R	Обґрунтування
Д1, П1	З-01 цільовий фішинг і викрадення облікових даних операторів Реєстру	10	дуже високий	високий	7	цільові фішингові кампанії проти держорганів; MFA для операторів відсутня
Д1	З-02 несанкціонована зміна облікових записів військовозобов'язаних (корупційне втручання)	10	середній	високий	6	широкі права операторів, зміни записів не перевіряються другою особою
Д2, Д4	З-03 витік персональних і медичних даних	9	середній	середній	5	медичні дані на сервері без маскування; DLP відсутня
П2	З-04 dDoS-атака на сервіс електронної черги	4	високий	високий	5	сервіс черги має єдиний канал без фільтрації трафіку
П1, Ф1	З-05 атака через ланцюг постачання (шкідливе оновлення ПЗ)	10	низький	середній	5	оновлення надходять від постачальника, цілісність перевіряється не завжди
Ф1, Д6	З-06 програма-вимагач або вайпер у локальній мережі	9	середній	високий	6	пласка ЛОМ, резервні копії зберігаються в мережі
Ф3, Д3	З-07 фізичне проникнення, підключення пристрою, крадіжка носія	10	низький	низький	4	охоронювана зона РСО, автономні АРМ без мережі
Ф2	З-08 компрометація засобів КЗІ та ключових документів	10	низький	низький	4	облік ключових документів за правилами Держспецзв'язку
Д1, Д6	З-09 заперечення виконаних дій операторами (відсутність доказовості)	10	середній	середній	5	журнали є, але не захищені від зміни адміністратором
Ф1, Ф2	З-10 відмова обладнання або живлення під час обстрілів	10	високий	середній	6	відключення живлення під час обстрілів; генератор є, резервного каналу немає

Розподіл мір ризику: R = 7 — 1; R = 6 — 3; R = 5 — 4; R = 4 — 2. Найбільшу міру має З-01 (цільовий фішинг і викрадення облікових даних операторів реєстру, R = 7); міру 6 — З-02, З-06, З-10. Загрози З-07 і З-08 мають міру 4: попри найвищу цінність активів, низька вразливість (ізольовані АРМ,

облік ключів) утримує їх на рівні прийнятного ризику, визначеного в контексті (не більше 4).

4.5. Етап 3: вибір контрзаходів

Контрзаходи обрано з груп бібліотеки CRAMM за аспектами безпеки (табл. 2.5). Пріоритет мають заходи, що захищають від кількох загроз, і заходи для систем з мірою ризику 6–7 [6].

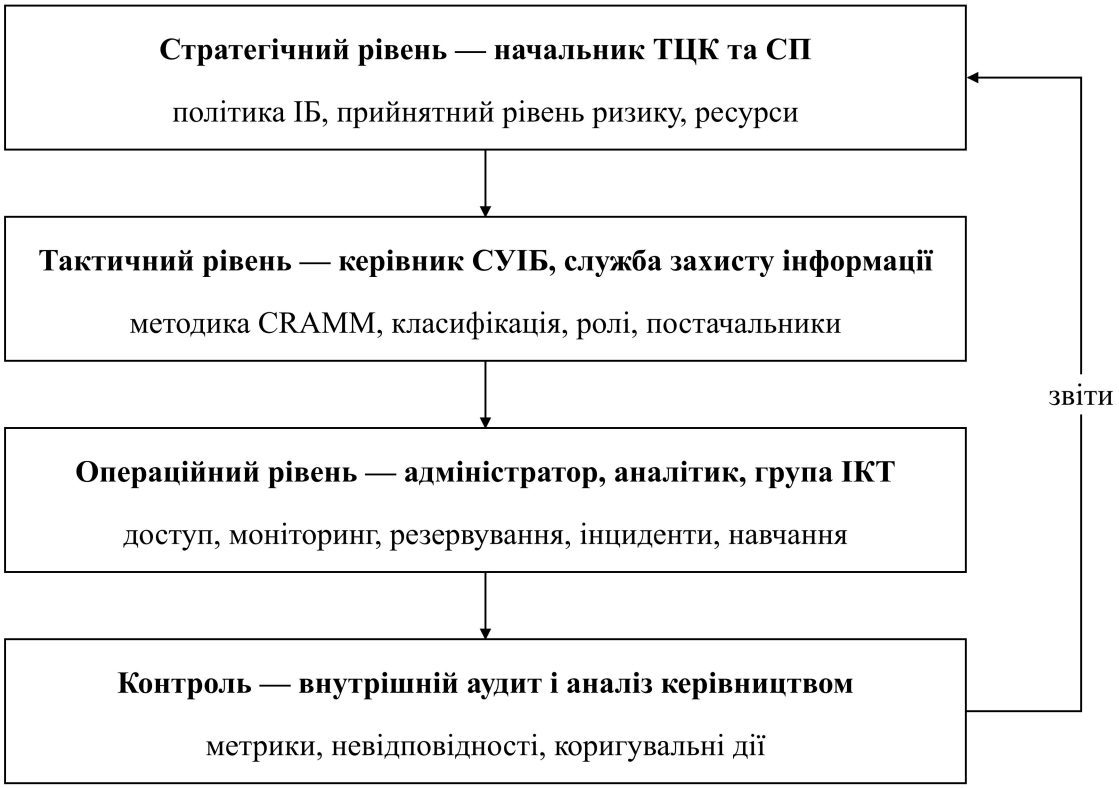
Таблиця 2.5 — Етап 3 CRAMM: групи контрзаходів для ТЦК та СП

Група CRAMM	**Контрзаходи для ТЦК та СП**	**Загрози**
Апаратні	резервний сервер документообігу, ДБЖ і генератор з автоматичним перемиканням	З-10, З-06
Програмні	багатофакторна автентифікація операторів, EDR, контроль цілісності оновлень, DLP	З-01, З-03, З-05, З-06
Комунікаційні	анти-DDoS-фільтр і WAF для сервісу черги, резервний канал, сегментація VLAN	З-04, З-06, З-10
Процедурні	принцип «чотирьох очей» для змін записів Реєстру, захищене журналювання, план реагування	З-02, З-09
Фізичні	контроль доступу до приміщень, блокування USB-портів, сейфове зберігання носіїв	З-07, З-08
Кадрові	навчання протидії фішингу, перевірка при оформленні допуску, відповідальність за порушення	З-01, З-02
Середовищні	захист серверної від перегріву й затоплення, резервне живлення приміщення РСО	З-10

Найвищий пріоритет мають програмні заходи (захищають від 4 загроз) і комунікаційні заходи (захищають від 3 загроз): багатофакторна автентифікація, EDR, контроль оновлень, фільтрація трафіку та сегментація одночасно знижують ризики З-01, З-04, З-05 і З-06. Процедурний принцип «чотирьох очей» — головний захід проти корупційного втручання З-02, яке технічні засоби самі не усувають.

5. АСПЕКТИ УПРАВЛІНСЬКОЇ РОБОТИ ЩОДО ЗАБЕЗПЕЧЕННЯ ІБ У ТЦК ТА СП

Управлінську роботу з інформаційної безпеки в ТЦК та СП розподілено за рівнями (рис. 2.3). Стратегічний рівень ухвалює рішення й надає ресурси, тактичний перетворює їх на методики й правила, операційний виконує заходи, а контроль повертає керівництву звіти про стан ризиків. Така побудова відповідає вимогам розділів 5, 6 і 9 ISO/IEC 27001:2022 [7].



Вниз — рішення і ресурси; вгору — звіти про стан ризиків

Рис. 2.3 — Рівні управлінської роботи щодо забезпечення ІБ у ТЦК та СП

Основні аспекти управлінської роботи щодо забезпечення інформаційної безпеки на рівні ТЦК та СП, відповідальні виконавці й документовані результати наведено в табл. 2.6.

Таблиця 2.6 — Аспекти управлінської роботи щодо забезпечення ІБ у ТЦК та СП

Рівень	Аспект	Відповідальний	Результат
Стратегічний	Політика інформаційної безпеки та цілі СУІБ	начальник ТЦК та СП	наказ про затвердження політики, цілі на рік
Стратегічний	Визначення прийнятного рівня ризику та власників ризиків	начальник ТЦК та СП	критерії прийняття ризиків (міра CRAMM ≤ 4)
Стратегічний	Розподіл ресурсів: персонал, бюджет, засоби захисту	начальник, фінансово-господарське відділення	план закупівель засобів захисту
Тактичний	Організаційна структура СУІБ, ролі й повноваження	заступник начальника (керівник СУІБ)	положення про службу захисту інформації
Тактичний	Методика оцінки ризиків і періодичність переоцінки	служба захисту інформації	методика на основі CRAMM, щорічна переоцінка
Тактичний	Класифікація інформації та порядок доступу	служба захисту інформації, РСО	перелік відомостей, матриця доступу
Тактичний	Безпека відносин з постачальниками ПЗ і зв’язку	група ІКТ та зв’язку	вимоги безпеки в договорах
Операційний	Керування доступом та обліковими записами	адміністратор безпеки	журнал видачі й відкликання прав
Операційний	Моніторинг подій і реагування на інциденти	аналітик подій, взаємодія з CERT-UA	звіти SIEM, картки інцидентів
Операційний	Резервне копіювання та неперервність	група ІКТ та зв’язку	графік резервування, план відновлення
Операційний	Навчання та підвищення обізнаності персоналу	служба захисту інформації	журнал інструктажів, результати фішинг-тренувань
Контроль	Внутрішній аудит і аналіз керівництвом	керівник СУІБ, начальник	звіт аудиту, протокол аналізу

Особливості ТЦК та СП як державного органу: персональні дані громадян обробляються на підставі закону [9], ведення Реєстру регулюється окремим законом [10], а кіберзахист державних інформаційних ресурсів і повідомлення CERT-UA про інциденти є обов’язковими [11]. Тому управлінська робота поєднує вимоги СУІБ з національним порядком створення КСЗІ [12]. Ризики, оцінені за CRAMM, і порушники з ЛР1 стають

вихідними даними для моделі загроз і моделі порушника КСЗІ, а ступінь ризику, пов’язаний з посадою працівника, ураховують під час розподілу прав доступу [13].

6. МЕТОДИКИ УПРАВЛІННЯ РИЗИКАМИ ДЛЯ ТЦК ТА СП

За завданням 5 таблицю методик (форма таблиці 3.1 методичних рекомендацій [1]) заповнено всіма методиками, що можуть бути застосовані для безпеки ТЦК та СП, і розширено методиками, які найкраще відповідають діяльності державного органу: міжнародними стандартами процесу (ISO/IEC 27005, ISO 31000), методами моделювання загроз і аналізу впливу з лекцій курсу [3; 14] та національним порядком створення КСЗІ [12]. Описи методик ґрунтуються на першоджерелах [8; 15; 16; 17; 18] (табл. 2.7).

Таблиця 2.7 — Методики управління ризиками та їх застосування в ТЦК та СП

Методика	Опис методики	Застосування в ТЦК та СП
CRAMM	Три етапи: оцінка активів (1–10), оцінка загроз і вразливостей з мірою ризику 1–7, вибір контрзаходів з бібліотеки; державний профіль для урядових установ	Основна методика роботи: повний аналіз активів Реєстру, ВЛК та мобілізаційних документів (розділ 4)
ISO/IEC 27005:2022	Настанова з керування ризиками ІБ у межах СУІБ за ISO/IEC 27001: контекст, оцінювання, обробка, прийняття, комунікація, моніторинг	Рамка процесу, у яку вбудовано CRAMM; узгодження з Декларацією про застосовність ЛР1
ISO 31000:2018	Загальні принципи й процес управління ризиками будь-якої природи	Інтеграція кіберризиків у загальне управління ризиками ТЦК та СП
NIST SP 800-30 Rev. 1	Підготовка, проведення, повідомлення та підтримання оцінки ризиків; шкали ймовірності й впливу	Сценарні оцінки для відомчих ІТС, узгоджені з NIST CSF 2.0
COBIT 5 for Risk	Управління ІТ-ризиками з позицій врядування: функція ризику та процеси керування ризиками	Звітування начальнику, зв’язок ризиків з ІТ-процесами групи ІКТ
OCTAVE (OCTAVE-S, OCTAVE Allegro)	Самостійна оцінка силами працівників: профілі критичних активів, загрози, вразливості інфраструктури, стратегія захисту	Швидка самооцінка окремого відділення без зовнішніх консультантів
FRAP	Груповий якісний аналіз під керівництвом фасилітатора; ймовірність і вплив за шкалою висока / середня / низька	Короткі сесії з керівниками відділень для нових сервісів (наприклад, електронної черги)

Продовження таблиці 2.7

Методика	Опис методики	Застосування в ТЦК та СП
EBIOS	Французька методика (ANSSI) з циклу фаз: контекст, події, сценарії загроз, ризики, заходи	Аналіз сценаріїв атак державних угруповань на ланцюг постачання
MEHARI	Методика CLUSIF з базою знань для аудиту вразливостей і вибору заходів	Довідково: перевірка повноти заходів за базою знань
STRIDE і дерева атак	Моделювання загроз за шістьма категоріями та деревами сценаріїв атак (лекція 3)	Ідентифікація загроз для етапу 2 CRAMM (табл. 2.4)
Аналіз впливу на бізнес (BIA)	Критичність процесів, допустимий час простою (RTO) і втрати даних (RPO) (лекція 5)	Оцінки «недоступності» даних на етапі 1 CRAMM
НД ТЗІ 3.7-003-05	Національний порядок створення КСЗІ: обстеження, модель загроз і модель порушника, технічне завдання	Обов’язковий контур: результати CRAMM — вхідні дані для моделі загроз КСЗІ

Для ТЦК та СП доцільне поєднання: ISO/IEC 27005 як рамка процесу, CRAMM з державним профілем для детального аналізу критичних активів, STRIDE і BIA для ідентифікації загроз і оцінки недоступності, FRAP для швидкого аналізу нових сервісів і НД ТЗІ 3.7-003-05 як обов’язковий національний контур. Відповідно до рекомендацій методички великим організаціям відповідає CRAMM, середнім — FRAP, малим — OCTAVE [1]; районний ТЦК та СП як елемент великої державної системи належить до першої групи.

7. ПЕРЕВАГИ ТА НЕДОЛІКИ МЕТОДИК УПРАВЛІННЯ РИЗИКАМИ ІБ

Переваги й недоліки п’яти методик, визначених у таблиці 3.2 методичних рекомендацій [1], наведено в табл. 2.8. Оцінки CRAMM узгоджено з досвідом її застосування [6], OCTAVE — з описом підходу розробниками [19].

Таблиця 2.8 — Переваги та недоліки методик з управління ризиками ІБ

Методика	Переваги	Недоліки
CRAMM	поєднання кількісних і якісних оцінок; велика бібліотека контрзаходів; державний профіль; економічне обґрунтування витрат	потребує спеціального засобу та підготовленого аналітика; платна ліцензія; оцінки за найгіршим сценарієм можуть завищувати ризик
COBIT 5 for Risk	зв’язує ризики з врядуванням і цілями організації; узгоджений з COBIT 5	не містить детальної процедури розрахунку ризиків; потребує зрілих IT-процесів
FRAP	швидкість і простота; не потребує спеціальних засобів; залучає власників процесів	суб’єктивність групових оцінок; лише якісний результат; залежність від фасилітатора
NIST SP 800-30	детальна загальнодоступна настанова; шкали й приклади; узгодження з NIST CSF	орієнтація на федеральні системи США; трудомісткість для малих організацій
OCTAVE	безкоштовність; самостійне виконання працівниками; фокус на критичних активах	велика кількість робочих аркушів; якісні шкали без фінансової точності

Порівняння показує, що жодна методика не є універсальною: CRAMM найповніша, але найдорожча; FRAP і OCTAVE швидкі, але якісні; NIST SP 800-30 і COBIT 5 for Risk є радше рамками, ніж готовими інструментами розрахунку. Для ТЦК та СП це обґрунтовує комбінований підхід, описаний у розділі 6.

8. ВІДПОВІДІ НА ПИТАННЯ ДЛЯ САМОПЕРЕВІРКИ

Питання 1. За допомогою яких механізмів здійснюється управління ризиками на підприємстві?

Відповідь. Політика й критерії прийняття ризиків, призначення власників ризиків, методика оцінювання (у ТЦК та СП — CRAMM), реєстр ризиків, план обробки з контрзаходами, моніторинг, внутрішній аудит і аналіз керівництвом (розділ 2.2, табл. 2.6).

Питання 2. Що є управлінням інформаційною безпекою?

Відповідь. Це частина загальної системи управління підприємством: скоординована діяльність керівництва на стратегічному, тактичному й операційному рівнях, спрямована на досягнення цілей конфіденційності, цілісності й доступності через управління ризиками (рис. 2.3).

Питання 3. Основні положення методології CRAMM?

Відповідь. Три етапи: ідентифікація й оцінка активів (1–10), оцінка загроз (5 рівнів) і вразливостей (3 рівні) з мірою ризику 1–7, вибір контрзаходів з бібліотеки за аспектами безпеки. Методика поєднує кількісні й якісні оцінки, має профілі для комерційних і державних організацій (розділ 4).

Питання 4. Що таке ресурси, загрози, вразливості?

Відповідь. Ресурси (активи) — дані, ПЗ, обладнання, приміщення, персонал і процеси, що мають цінність; загроза — потенційна небезпека для ресурсу; вразливість — слабке місце, через яке загроза може реалізуватися. Приклад для ТЦК та СП: відомості Реєстру — фішинг — відсутність MFA (табл. 2.4).

ВИСНОВКИ

У лабораторній роботі досліджено процес управління ризиками кібернетичної безпеки військкомату — районного ТЦК та СП — за методикою CRAMM.

1) Розкрито поняття ризику, загрози, вразливості та управління ризиками і чотири способи обробки ризиків з прикладами для ТЦК та СП.

2) Описано процес управління ризиками за ISO/IEC 27005 і ISO 31000 з двома точками рішень і наповненням кожного етапу для ТЦК та СП (табл. 2.1).

3) Застосовано три етапи CRAMM: оцінено 6 груп даних і 5 груп ПЗ та фізичних активів; 9 з 11 мають цінність 8 і вище, тому потрібен детальний аналіз.

4) Для 10 загроз обчислено міру ризику: найвища — R = 7 (З-01, цільовий фішинг), міру 6 мають 3, прийнятну міру 4 — 2.

5) Сформовано 12 аспектів управлінської роботи на чотирьох рівнях і таблицю з 12 методик з обґрунтуванням їх застосування; порівняно переваги й недоліки п’яти методик.

Аналіз результатів показує, що для ТЦК та СП найважливіші не окремі технічні засоби, а заходи, які одночасно перекривають кілька загроз (багатофакторна автентифікація, сегментація, EDR), і процедурний контроль змін записів Реєстру. CRAMM дала змогу обґрунтувати цей пріоритет кількісно, а комбінація з ISO/IEC 27005 і НД ТЗІ 3.7-003-05 забезпечує відповідність як міжнародним практикам, так і національним вимогам.

СПИСОК ВИКОРИСТАНИХ ДЖЕРЕЛ

1. Борисенко І. І., Гладка М. В. Кібернетична безпека підприємства : рекомендації до виконання лабораторних робіт для здобувачів освітнього ступеня «бакалавр» спеціальності 126 «Інформаційні системи та технології». Київ : КНУ імені Тараса Шевченка, 2025. 33 с.

2. Про затвердження Положення про територіальні центри комплектування та соціальної підтримки : постанова Кабінету Міністрів України від 23.02.2022 № 154. URL: https://zakon.rada.gov.ua/laws/show/154-2022-п (дата звернення: 25.10.2026).

3. Кіберзагрози, вразливості та моделювання атак на підприємство : лекція 3 з дисципліни «Кібернетична безпека підприємства». Київ : КНУ імені Тараса Шевченка, 2026.

4. ISO 31000:2018. Risk management — Guidelines. Geneva : ISO, 2018.

5. ISO/IEC 27005:2022. Information security, cybersecurity and privacy protection — Guidance on managing information security risks. Geneva : ISO, 2022.

6. Yazar Z. A qualitative risk analysis and management tool — CRAMM : GSEC practical assignment. SANS Institute, 2002. URL: https://www.giac.org/paper/gsec/1746/qualitative-risk-analysis-management-tool-cramm/103133 (дата звернення: 25.10.2026).

7. ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection — Information security management systems — Requirements. Geneva : ISO, 2022.

8. Risk Management: Implementation principles and Inventories for Risk Management/Risk Assessment methods and tools. Heraklion : ENISA, 2006. URL: https://www.enisa.europa.eu/sites/default/files/publications/D1_Inventory_of_Methods_Risk_Management_Final.pdf (дата звернення: 25.10.2026).

9. Про захист персональних даних : Закон України від 01.06.2010 № 2297-VI. URL: https://zakon.rada.gov.ua/laws/show/2297-17 (дата звернення: 25.10.2026).

10. Про Єдиний державний реєстр призовників, військовозобов'язаних та резервістів : Закон України від 16.03.2017 № 1951-VIII. URL: https://zakon.rada.gov.ua/laws/show/1951-19 (дата звернення: 25.10.2026).

11. Про основні засади забезпечення кібербезпеки України : Закон України від 05.10.2017 № 2163-VIII. URL: https://zakon.rada.gov.ua/laws/show/2163-19 (дата звернення: 25.10.2026).

12. НД ТЗІ 3.7-003-05. Порядок проведення робіт із створення комплексної системи захисту інформації в інформаційно-телекомунікаційній системі. Київ : ДСТСЗІ СБ України, 2005.

13. Порушник у системі кібернетичної безпеки підприємства : лекція 4 з дисципліни «Кібернетична безпека підприємства». Київ : КНУ імені Тараса Шевченка, 2026.

14. Організаційний та процедурний рівень кібернетичної безпеки підприємства : лекція 5 з дисципліни «Кібернетична безпека підприємства». Київ : КНУ імені Тараса Шевченка, 2026.

15. Guide for Conducting Risk Assessments : NIST Special Publication 800-30 Revision 1. Gaithersburg : National Institute of Standards and Technology, 2012. 95 p.

16. COBIT 5 for Risk. Rolling Meadows : ISACA, 2013.

17. Caralli R. A., Stevens J. F., Young L. R., Wilson W. R. Introducing OCTAVE Allegro: Improving the Information Security Risk Assessment Process : CMU/SEI-2007-TR-012. Pittsburgh : Software Engineering Institute, 2007. 154 p. URL: https://courses.cs.ttu.ee/w/images/a/a3/OCTAVE.pdf (дата звернення: 25.10.2026).

18. Peltier T. R. Information Security Risk Analysis. 3rd ed. Boca Raton : CRC Press, 2010.

19. Alberts C., Dorofee A. Managing Information Security Risks: The OCTAVE Approach. Boston : Addison-Wesley, 2002. 471 p.